



2026 지방직 대비 핵심 25개 표

작성: 2026-05-19

표중심 요약노트 — 시험장 직전 5분 정리용

이 노트는 마스터 노트의 보완으로, **표 25개에 핵심 함정 압축**. 마지막 회독에 이 한 권만 보면 충분.

표 1. 정보보호 3대 목표 (CIA) + 확장 5요소

목표	정의	침해 사례	대책 기술	빈출 키워드
기밀성	인가자만 접근	도청, 스니핑	대칭/공개키 암호화	도청, 트래픽 분석 = 수동적
무결성	위·변조 방지	메시지 변조	해시, MAC, 전자서명	위변조 방어 = 무결성
가용성	적시 사용	DoS, 지진	백업, RAID, 이중화	백업, 중복성, 서비스거부
인증성	신원 검증·출처 확인	위장	인증서, 패스워드	“사용자 신원·메시지 출처”
부인방지	사후 부인 차단	거래 부인	전자서명	발신/수신 부인
책임추적성	누가·언제·어떻게 추적	무로그 행위	감사 로그	“추적할 수 있도록”

표 2. 암호 알고리즘 분류 (대칭 vs 비대칭)

구분	알고리즘
대칭키 블록	DES, 3DES, AES, SEED, ARIA , IDEA, LEA , Blowfish, Twofish
대칭키 스트림	RC4, A5/1 , A5/2, ChaCha20
비대칭 인수분해	RSA , Rabin
비대칭 이산대수	ElGamal, DSA, Schnorr, 디피-헬만
비대칭 타원곡선	ECC, ECDSA, ECDH
공개키 함정	배낭암호 (NP-완전 기반, 거의 취약)
× 함정	디피-헬만 ≠ 대칭, ECC ≠ 대칭, A5/1 ≠ 공개키

표 3. 블록 암호 운영 모드 5가지 (최빈출)

모드	식 / 구조	패턴 노출	병렬(암호화)	병렬(복호화)	오류 전파	IV/Nonce	핵심 키워드
ECB	$C_i = E_K(P_i)$	O (취약)	O	O	해당 블록만	불필요	같은 평문→같은 암호
CBC	$C_i = E_K(P_i \oplus C_{i-1})$	X	X (직렬)	O	$C_i \text{ 오류} \rightarrow P_i, P_{i+1}$	필수	이전 블록 영향
CFB	$C_i = E_K(C_{i-1}) \oplus P_i$	X	X	O	오류→해당+다음	필수	스트림화, 자기 동기
OFB	$O_i = E_K(O_{i-1}),$ $C_i = O_i \oplus P_i$	X	X	X	오류 비전파	필수	오류 한 비트만
CTR	$C_i = E_K(\text{Nonce} \parallel i) \oplus P_i$	X	O (완벽)	O	해당 블록만	Nonce+카운터	병렬화 가능, 무작위 접근

시험 패턴: - “동일 평문 동일 암호문 + 오류 전파” → OFB만 모두 해결 - “병렬 처리 + 카운터” → CTR - “이전 블록과 XOR” → CBC

표 4. 접근 통제 모델 4가지

모델	정책	중심	규칙	적용
DAC (임의적)	소유자 결정	자율	ACL, UNIX 권한	일반 OS
MAC (강제적)	시스템 결정	보안 등급	No Read Up/Down	군사
BLP	강제적	기밀성	No Read Up, No Write Down	군사
Biba	강제적	무결성	No Read Down, No Write Up	시스템
Clark-Wilson	-	상업 무결성	트랜잭션, 직무분리, CDI 검증	금융
Chinese Wall	-	이해충돌	경쟁사 동시 접근 금지	컨설팅
RBAC	-	역할	역할에 권한 할당	기업

기억법: “기밀=BLP, 무결=Biba, 상업무결=Clark, 충돌=Chinese”

표 5. AES 라운드 & 라운드 연산

키 크기	라운드 수	블록 크기
128 bit	10	128
192 bit	12	128
256 bit	14	128

라운드 구성: - 마지막 라운드: SubBytes + ShiftRows + AddRoundKey (MixColumns 생략 △) - 나머지: 4개 연산 모두 수행

표 6. 해시 알고리즘 비교

알고리즘	출력 (bit)	블록 (bit)	라운드	안전성
MD5	128	512	64	취약
SHA-1	160	512	80	취약
SHA-224	224	512	64	안전
SHA-256	256	512	64	안전
SHA-384	384	1024	80	안전
SHA-512	512	1024	80	안전
SHA-3 (Keccak)	가변	가변	-	최신

충돌 작업량: n-bit 해시 → 2^(n/2) (생일 역설)

표 7. 비대칭키 알고리즘 정리

알고리즘	기반 문제	암호화	키교환	서명
RSA	소인수분해	O	O	O
ElGamal	이산대수	O	O	O
디피-헬만	이산대수	X	O	X
DSA/DSS	이산대수	X	X	O
Schnorr	이산대수 + q p-1	X	X	O
ECC	타원곡선 이산대수	O	O	O
ECDSA	타원곡선	X	X	O

표 8. IPSec 두 프로토콜 + 두 모드

프로토콜	인증	기밀성	무결성	헤더 인증 범위
AH (Auth Header)	O	X	O	IP 헤더 포함
ESP (Encap Security Payload)	선택	O	O	IP 헤더 미포함

모드	보호 범위	용도	IP 헤더
전송 모드	페이로드만	호스트-호스트	원본 유지
터널 모드	전체 IP 패킷	VPN	새 IP 헤더 추가

키 관리: IKE (ISAKMP 사용)

표 9. SSL/TLS 4개 프로토콜

프로토콜	역할
Handshake	인증서 확인, 세션키 교환, 알고리즘 협상
ChangeCipherSpec	협상 매개변수 활성화
Alert	오류·경고 전달
Record	단편화 → 압축(옵션) → MAC → 암호화 → 헤더 (2026 국 가직 4번)

Handshake 목적 (택 2): 인증서 확인, 세션키 교환 (응용 데이터 전송 X, 세션 유지 X)

표 10. SSH 3개 프로토콜 (RFC 4251)

프로토콜	역할
전송 계층	서버 인증, 기밀성, 무결성, 압축(옵션)
사용자 인증	클라이언트(사용자)→서버 인증
연결	암호화 채널에 여러 논리 채널 다중화

△ 함정: - “Handshake” 프로토콜은 SSH 구성요소 X (그건 TLS) - “연결 프로토콜이 사용자 인증”이 X - “전송 프로토콜이 채널 다중화”가 X (그건 연결)

표 11. 무선 LAN 보안 진화

표준	암호	무결성	키 관리	약점
WEP	RC4	CRC-32	고정 PSK	IV 24bit, 키 노출
WPA	RC4 + TKIP	Michael MIC	동적 키	TKIP 취약
WPA2	AES-CCMP	CCM	IEEE 802.11i	KRACK
WPA3	AES + SAE (Dragonfly)	GCMP	PFS	최신

모드: - 개인(Personal): PSK 기반 - 엔터프라이즈(Enterprise): RADIUS + EAP

표 12. 주요 공격 기법 6선

공격	원리	표적
SYN Flooding	SYN만 보내고 ACK 안 보냄 → 백로그 큐 고갈	TCP
Smurf	발신지=피해자, ICMP를 브로드캐스트	ICMP
Land	발신지=목적지 IP	TCP/IP
Teardrop	IP 조각 오프셋 조작 → 재조합 오류	IP
Slowloris	HTTP 헤더 천천히 전송 → 연결 점유	HTTP
Pharming	호스트파일·DNS 조작 → 가짜 사이트 (DoS 아님)	DNS

표 13. 웹 공격 4선

공격	설명	방어
SQL Injection	입력에 SQL 삽입	Prepared Statement
XSS	스크립트 브라우저 실행	출력 인코딩, CSP
CSRF	인증된 사용자가 의도치 않은 요청	CSRF 토큰
SSRF	서버가 내부망 요청	화이트리스트

입력 검증 누락 공격이 아닌 것: HTTP GET Flooding (그건 DoS)

표 14. ISMS-P 구조 PDCA

사이클	영역	항목 수
P (Plan)	관리체계 기반 마련	6
D (Do)	위험 관리	4
C (Check)	관리체계 운영	3
A (Act)	관리체계 점검 및 개선	3

보호대책 요구사항 12분야 (64항목): 정책·조직·자산 | 인적 | 외부자 | 물리 | 인증·권한 | 접근통제 | 암호화 | 도입·개발 | 운영관리 | 보안관리 | 사고예방·대응 | 재해복구

× 보호대책 분야 X: 정보주체 권리보호 (그건 개인정보 처리단계별)

표 15. 위험 분석 접근법 + 위험 처리

위험 분석: | 방법 | 특징 | | — | — | | 기준선 | 표준 체크리스트 | | 비정형 | 전문가 지식·경험 | | 상세 | 자산·위험·취약점 평가 | | 복합 | 고위험=상세, 기타=기준선 |

정성적 vs 정량적: - 정성적: 델파이법, 시나리오, 순위결정, 브레인스토밍 (전문가 토론) - 정량적: 과거자료, 확률분포, 수학공식, $ALE = SLE \times ARO$

위험 처리: | 방법 | 정의 | | — | — | | 수용 | 받아들이고 손실 감수 | | 감소 | 통제·대책 적용 | | 회피 | 행위·시스템 수행 안 함 | | 전가 | 보험, 외주 계약 |

표 16. 정보보호 평가 기준 4가지

기준	발행	등급	중심
TCSEC	미국 (Orange Book)	A1>B3>B2>B1>C2>C1>D	기밀성
ITSEC	유럽	F1~F10, E0~E6	기능 + 보증 분리
CC	ISO 15408 국제	EAL 1 (최저) ~ EAL 7 (최고)	보호 프로파일
ISO/IEC 27001	ISO 국제	인증	ISMS

CC 보증 요구사항 7개: 보호 프로파일, 보안 목표, 개발, 가이드 문서, 생명주기, 시험, 취약점 평가

표 17. 디지털 포렌식 원칙 5가지

원칙	정의
정당성	적법 절차로 입수
무결성	위·변조 없음 증명
재현성	같은 조건 → 같은 결과
신속성	취발성 정보 빠르게 수집
연계 보관성	획득→이송→분석→보관→법정 제출 추적

대검찰청 규정 원칙 3가지 (2026 국가직 11번): 적법절차, 신뢰성, **원본성** (“기밀성” X)

표 18. 개인정보 보호법 핵심 조문 10선

조문	핵심
제2조	개인정보 = 살아 있는 개인 (사망자 X)
제3조	처리 목적 명확, 최소 수집, 정확·완전·최신, 공개, 익명 우선
제4조	정보주체 권리 6가지 (자동화 결정 거부·설명 권리 포함)
제15조	수집·이용 6가지 사유 (“ 정보주체와의 계약 ”)
제17조	제3자 제공 동의 시 5개 알릴 사항
제21조	파기: 대통령령 , 지체 없이, 복구 불가
제26조	위탁: 수탁자 초과 이용 금지
제28조의2	가명정보 — 통계·연구·공익보존 동의 없이
제30조	처리방침 공개 (목적, 기간, 권리행사)
제31조	보호책임자 업무 (처분 권한 X)
제35조	열람 제한 사유

표 19. 개인정보 보호위원회 위원 자격 (제7조의2)

자격 요건	기간
보호 업무 담당 3급 이상 공무원	-
판사·검사·변호사	10년 이상
공공기관·단체 추천, 보호 업무 담당	3년 이상
대학 부교수 이상	5년 이상 △ (“3년 이상”이 함정)

표 20. 법률별 소관 부처

법률	소관 부처
개인정보 보호법	개인정보 보호위원회
정보통신망법	과학기술정보통신부, 방송통신위원회
위치정보법	방송통신위원회 △ (과기정통부 X)
정보공개법	행정안전부
전자서명법	과학기술정보통신부
정보통신기반보호법	과학기술정보통신부
신용정보법	금융위원회

표 21. 보안관제 전문기업 지정 기준 (2026 국가직 20번)

항목	기준
법인 설립	5년 이상
자기 자본	20억원 이상
평가 점수	70점 이상
기술인력	15명 이상 (고급 3명 이상, 중급 6명 이상 포함)

표 22. ISMS-P 인증심사원 (2022 국가직 20번)

항목	기준
자격 유효기간	3년
보수교육	자격 유효기간 동안 이수
선임 심사원 요건	자격 취득자 + 심사 3회 이상 참여 + 심사일수 15일 이상
자격 취소 사유	정보 누설, 업무목적 외 사용

표 23. 신유형 키워드 사전 (2026 대비)

용어	정의	핵심
CAPTCHA	컴퓨터-사람 구분 자동 튜링	인증 (기밀성 X)
NAC	MAC 기반 접근 제어	IP 관리에서 발전
DLP	데이터 유출 방지	USB·메일·네트워크
DRM	디지털 권리 관리	저작권 보호
VPN	가상 사설망	IPSec, L2TP, PPTP, SSL
SIEM	보안 이벤트 관리	로그 통합·상관
EDR/XDR	엔드포인트 탐지·대응	행위 분석
제로트러스트	Never Trust, Always Verify	ZTNA
SASE	네트워크+보안 통합	SD-WAN + ZTNA + CASB
CASB	클라우드 접근 보안 중개	SaaS DLP
CSPM	클라우드 보안 자세 관리	설정 오류 탐지
PQC	양자내성암호	ML-KEM, ML-DSA (NIST 2024)
데이터 포이즈닝	AI 학습 데이터 오염	백도어 트리거
적대적 공격	AI 추론 시 미세 변형	회피 공격
SBOM	소프트웨어 구성 명세	공급망 보안
머클 트리	이진 트리, SHA-256, 32바이트	블록체인 무결성

표 24. 자주 헛갈리는 함정 모음 (Top 15)

헛갈림	옳은 것
디피-헬만이 대칭키?	비대칭키 (키 교환)
Biba가 임의적?	강제적, 무결성
BLP가 무결성?	기밀성
ECC가 대칭?	비대칭 (타원곡선)
FRR이 오수락?	오거부 (FAR가 오수락)
Pharming이 DoS?	호스트·DNS 조작
CC EAL 1이 최고?	EAL 7이 최고
위치정보법이 과기정통부?	방통위
처리방침을 비공개?	공개
가명 우선?	익명 우선 , 안 되면 가명
자동화 결정을 승인 권리?	거부·설명 요구 권리
공공기관과의 계약?	정보주체와의 계약
가명정보 파기 = 총리령?	대통령령
HKEY_CURRENT_CONFIG = 실시간 성능?	HW 프로파일
Kerberos v5가 nonce 미사용?	사용함 (재생 공격 방어)

표 25. 시험 1주 전 최종 점검표

암호 계산

- ☐ AES 라운드 수 외우기 (128→10, 192→12, 256→14)
- ☐ SHA-512 (라운드 80, 블록 1024)
- ☐ CC EAL 1(최저)~7(최고)
- ☐ 생일 역설 = $2^{n/2}$
- ☐ Z_{26} 곱셈역원 = $\gcd(a, 26)=1$

법규 숫자

- ☐ 인증심사원 자격 유효기간: **3년**
- ☐ 선임심사원: **3회 + 15일**
- ☐ 보안관계 전문기업: **5년 + 20억 + 70점 + 15명(고급3, 중급6)**
- ☐ 손해배상: 법정 300만, 징벌 **5배**
- ☐ 부교수 **5년 이상** 재직

PDCA 순서

- ☐ **기반마련(P)→위험관리(D)→운영(C)→점검개선(A)**

모드·프로토콜 순서

- ☐ Record: **단편화→압축→MAC→암호화→헤더**
- ☐ 스택 반환: **(나)→(다)→(가)→(라)**

빈출 매칭

- ☐ BLP=기밀, Biba=무결, Clark-Wilson=상업무결, Chinese Wall=충돌
- ☐ AH=인증 only, ESP=인증+기밀
- ☐ FAR=오수락, FRR=오거부

END OF TABLES